

Chapter 11

Given a scenario, apply security principles to secure enterprise infrastructure

Infrastructure Considerations

- To secure an enterprise infrastructure, a holistic approach is needed, including assessing risk profiles, understanding threat landscapes, aligning security measures with business objectives, setting up security zones, implementing preventative controls, protecting access points, and adapting to emerging trends like cloud computing and IoT.
- A defense-in-depth model enhances network protection by creating multiple barriers and security measures. Considerations should be tailored to specific scenarios and sections of infrastructure.

We need to break up our considerations depending on the scenarios and specific sections of infrastructure

- **Device Placement**
- **Security Zones**
- **Attack Surface**
- **Connectivity**
- **Failure Modes**
- **Device attribute**

Device Placement:

- Device placement in a network strategically positions security, connectivity, and traffic management elements, defining network functionality and security, and is the foundation of network design and cyber security.
- The network is divided into three separate zones, Local Area Network (LAN), screened subnet, and Wide Area Network (WAN), and your devices should be placed in these zones depending on the security requirements
- The WAN is an untrusted zone, where bad guys lurk, like the internet. It's controlled by a router and ACL.
- The screened subnet, a Demilitarized Zone (DMZ), is a buffer zone between the WAN and LAN. It is the place where resources that can be accessed by both the trusted and untrusted zones
- The third zone, the LAN, is trusted and secure. A firewall ensures traffic is assessed twice before accessing the LAN.

Security Zones:

Security zones are distinct network segments with unique security policies, access controls, and trust levels. They compartmentalize networks, reducing access to users, devices, or systems. Strategic deployment of security zones is crucial for effective security, safeguarding assets, privacy, and trust in an interconnected world.

Key features of security zones include the following:

- **Segmentation:** Security zones divide networks into logical or physical segments based on user roles, device types, or data sensitivity, ensuring security and privacy.
- **Data Protection:** Data protection involves storing information in databases or file servers, ensuring sensitivity through Full Disk Encryption (FDE). Data should be classified and stored in different zones, with cloud-dispersed regions being useful for backup. Using Data Loss prevention (DLP) is a must. Data should be centrally held and not on client devices, with VPN access. Audit trails and logging are essential for data integrity.
- **Access Control:** Each security zone enforces specific access controls and policies. For example, a DMZ may allow limited external access to web servers while prohibiting access to the internal network. A LAN will only be accessible to the employees of the organization.

Security zones

- **Monitoring and Logging:** Employing real-time monitoring using **Security Information and Event Management (SIEM)** in tandem with a cutting-edge **Security Orchestration, Automation, and Response (SOAR)** system ensures data sanctity and integrity in the ever-evolving landscape of cybersecurity.
- **Isolation:** Security zones isolate potential breaches or cyberattacks, preventing them from spreading laterally across the network and reducing their threat.
- **Compliance:** Many regulatory frameworks, such as HIPAA and PCI DSS, mandate the use of security zones to protect sensitive data. Compliance is critical for organizations in various industries.
- **Incident containment:** In the event of a breach or cyberattack, security zones limit the lateral movement of attackers, contain the impact, and facilitate effective incident response.
- **Operational efficiency:** Security zones streamline network management so that IT administrators can focus their efforts on specific zones, making it easier to monitor, configure, and respond to security events.
- **Defense in depth:** Security zones are a cornerstone of the “defense-in-depth” strategy. They add layers of security, making it more challenging for attackers to penetrate and traverse the network.

Attack Surface

The network attack surface is the digital perimeter of an organization, containing various entry points and potential vulnerabilities that could allow unauthorized access, data manipulation, or disruption.

The following list will explore some key aspects of the attack surface and how to minimize the threat to each:

- **Endpoints:** Devices such as computers, smartphones, and IoT devices that connect to the network are primary targets. Vulnerabilities in endpoint operating systems, software, or configurations can provide a foothold for attackers.
- **Network services:** Services such as web servers, email servers, and VPN gateways expose themselves to the internet, becoming potential entry points. Inadequate patching, misconfigurations, or outdated software can lead to exploitation.
- **Ports and protocols:** Open ports and protocols on network devices create opportunities for attackers to probe and exploit weaknesses. Unnecessary open ports or unused services should be closed or disabled.
- **User accounts and credentials:** Weak or compromised passwords pose a significant security risk as attackers may employ brute-force attacks or phishing to obtain legitimate credentials and gain unauthorized access.
- **Third-party integrations:** Integrations with external services or third-party applications can introduce vulnerabilities. Regular security assessments and audits are crucial.
- **Cloud services:** As organizations migrate to the cloud, cloud based assets become potential targets. Misconfigured cloud resources can expose sensitive data.
- **Human factor:** Employees, whether through ignorance or malicious intent, can inadvertently contribute to the attack surface. Security awareness training is an essential preventative measure.

Minimizing the attack surface can be achieved using the following methods:

- **Vulnerability assessment:** Regularly scan and assess your network for vulnerabilities. Identify and patch or mitigate weaknesses promptly.
- **Access control:** Implement strict access controls and the principle of least privilege. Limit user access and permissions to only what's necessary.
- **Network segmentation:** Divide your network into segments to limit lateral movement for attackers. This isolates critical assets from less secure areas.
- **Single point of failure:** When you are deploying network appliances, ensure that you are not reliant on a single device lest it fail and take your entire network down with it. Look at building in resilience.
- **Security updates:** Keep all software, operating systems, and devices up to date with security patches. Remove or disable unnecessary services.
- **Strong authentication:** Enforce robust password policies and consider Multi-Factor Authentication (MFA) for critical systems.
- **Regular auditing:** Conduct regular security audits, penetration testing, and monitoring to detect and respond to suspicious activity. Ensure proper change management controls are in place.
- **Security awareness:** Educate employees about security best practices, including how to recognize and report potential threats.

Connectivity

Connectivity encompasses wired and wireless connections, cloud integrations, remote access, and information flow within a networked ecosystem. Factors like company size, security requirements, and remote working influence connection setup, impacting the intricate web of pathways.

- **Scalability:** As organizations grow, the demand for seamless connectivity escalates. Balancing scalability with performance becomes crucial to meeting evolving needs.
- **Security:** The more interconnected a network becomes, the more vulnerable it can be to cyber threats. Security measures must be tightly integrated into connectivity strategies.
- **Redundancy:** Ensuring uninterrupted connectivity requires redundancy and failover mechanisms to prevent single points of failure from disrupting operations.
- **Complexity:** Modern networks are multifaceted with various components and technologies. Managing this complexity is essential to maintaining reliability.
- **Remote work:** The rise of remote work relies heavily on connectivity, which allows employees to collaborate seamlessly from anywhere.

Failure Modes

- **Failure modes** dictate device behavior during malfunctions, crucial in engineering and safety systems. For instance, in bank security, an electric door lock system's failure mode prevents unauthorized access.
- Examples include **fail-closed**, which defaults to a closed state when a problem occurs, ensuring network security even during failures, and **fail-open**, which defaults to an open state when a problem occurs, creating a significant security vulnerability and potentially leading to data breaches and cyberattacks.

Device Attribute

- The devices in a network play important roles in safeguarding and monitoring data flow. Different categories of devices each have different functionalities and applications, as follows:
 - **Active devices**, such as firewalls and IPSs, are proactive in network security, proactively intervening when potential threats are detected, thereby ensuring network integrity and security.
 - **Passive devices**, like IDS, are observers that monitor network traffic, analyze patterns, and provide insights into potential threats and vulnerabilities, focusing on visibility and analysis rather than immediate blocking.
 - **Inline devices**, such as firewall appliances and load balancers, actively process network traffic, making real-time decisions on allowing or blocking data packets.
 - **Tap/monitor devices**, like network packet analyzers, duplicate network traffic for analysis or monitoring purposes, providing visibility without affecting original data flow, allowing for troubleshooting or security analysis.